~/majibill/docs/07-security-compliance.md

$ cat 07-security-compliance.md

MAJIBILL PLATFORM · SECURITY

Security, Privacy & Compliance

Threat model, tenant isolation, identity and access, data protection in Kenya, payment security, vulnerability management and incident response.

```
# least privilege, defence in depth
# customers' data belongs to the tenant
# not legal advice: confirm with counsel
```

DOC
MB-07

VERSION
1.0 draft

DATE
08 Oct 2026

STATUS
For review

AUDIENCE
Engineering, security, legal, management

CLASS
Confidential

// Contents

1. Security posture in one page 3

2. Threat model (STRIDE summary) 3

3. Identity and access 4

4. Data protection (Kenya) 5

5. Payment and money security 6

6. Application and infrastructure security 6

// 1. Security posture in one page

MajiBill holds names, phone numbers, addresses, consumption history and payment records for large populations, and it directs money to utilities. The posture is: **isolate tenants below the app, minimise and encrypt data, authenticate strongly, record everything that matters, and rehearse failure**.

Principle	In practice
Defence in depth	WAF, rate limits, authN/authZ, RLS, composite FKs, encryption, audit chain, alerts
Least privilege	Separate DB roles (app, migrator, reporter, audit-retention); scoped API keys; role-based UI and API
Secure by default	Deny by default permissions, MFA for staff, secure cookies, strict CSP, safe defaults for exports
Minimise data	Collect only what billing requires; mask in logs; short retention for raw payloads and photos
Assume breach	Detect (audit verifier, anomaly alerts), contain (cell isolation, key rotation), recover (PITR)

// 2. Threat model (STRIDE summary)

Threat	Scenario	Mitigations
Spoofing	Stolen staff password; fake M-Pesa callback	MFA for staff; callback secret path + source allow-list + transaction-status verification before posting; short sessions; device binding for reader app
Tampering	Insider edits a bill or deletes a payment	Append-only ledger and audit; maker–checker; revoked UPDATE/DELETE; hash chain and anchors
Repudiation	“I never approved that write-off”	Audit with actor, reason, IP, device; signed approvals
Information disclosure	Cross-tenant data leak; bulk export by insider; leaked backup	RLS + composite FKs + tests; export permission + audit + alerts; encrypted backups with separate keys
Denial of service	Callback flood; expensive report storm	WAF, per-tenant rate limits, queue isolation, read replica, statement timeouts
Elevation of privilege	Clerk grants self admin; SQL injection	Role-grant maker–checker; parameterised queries only; policy tests; separate DB roles
Supply chain	Malicious dependency or image	Pinned versions, scanners, SBOM, signed images, review of agent-added dependencies

> WATCH OUT **Agent-written code needs extra review at the boundaries**
> Agentic workflows are fast and fallible. Auth, tenancy, ledger and migration code require two human reviewers, golden tests and the CI policy checks before merge (MB-09).

// 3. Identity and access



Fig 3.1 Roles by realm. Platform and partner realms are separate from tenant realms.

Control	Standard
Passwords	Argon2id, breach-list check, no forced rotation without cause; account lockout with backoff
MFA	Mandatory for all staff and platform users (TOTP; WebAuthn later); optional OTP for customers via SMS
Sessions	HttpOnly, Secure, SameSite cookies; rotation; idle and absolute timeouts; revoke-all on role change
Mobile	Short-lived access token + refresh; device registration; remote wipe of cached data; PIN/biometric unlock
API keys	Scoped, hashed at rest, per-key rate limits, last-used tracking, expiry
Authorisation	RBAC with tenant scope; sensitive actions require recent re-auth; deny by default
SSO	OIDC/SAML adapter per tenant when required

3.1 Illustrative RBAC matrix (tenant realm)

Capability	Admin	Billing mgr	Clerk	Cashier	Reader	Auditor
Manage users and roles	Y					
Create/edit customers and accounts	Y	Y	Y			view
Capture and correct readings	Y	Y	Y		capture	view
Run cycle / approve bills	Y	Y				view
Request adjustment	Y	Y	Y			
Approve adjustment / write-off	Y	Y*				
Record cash payment	Y			Y		view
Resolve suspense payments	Y	Y		Y		view
View PII (national ID)	Y					Y
Export customer data	Y	Y				Y
View audit trail	Y	Y				Y

* Maker–checker applies: the approver cannot be the requester. Final matrix is configured per tenant.

// 4. Data protection (Kenya)

> WATCH OUT **Not legal advice**
> This section summarises the compliance work to plan. Have Kenyan counsel confirm obligations, especially while the company is not yet registered.

The Data Protection Act, 2019 and its regulations (administered by the Office of the Data Protection Commissioner, ODPC) distinguish **data controllers** (decide purpose and means) from **data processors** (process on a controller's behalf). In this model the **tenant utility is normally the controller** and 404HubSpot the **processor**; ZUCAR as reseller may be a processor or a joint party depending on its access. Confirm roles in writing.

Topic	What we do
Roles and contracts	Data processing agreement with every tenant; sub-processor list (cloud, SMS, email); partner agreement defining ZUCAR's access
Registration	Register as a data processor/controller with the ODPC where required once the company is incorporated; each tenant verifies its own registration
Lawful basis and notice	Tenants provide privacy notices to customers; platform supports consent records where consent is the basis
Impact assessment	DPIA for the platform and per large tenant (profiling-like features such as anomaly detection, location capture)
Data subject rights	Access, correction, deletion/anonymisation, portability: tooling in the console; ledger retained for legal obligations
Cross-border	Know where data and backups live; document transfers; offer in-country cells; safeguards in contracts
Breach handling	Detect, contain, notify tenant promptly; tenant (controller) notifies the regulator and data subjects within statutory timelines (commonly 72 hours; confirm)
Retention	Per-tenant policy; defaults in MB-04; delete or anonymise at end of contract after retention
Minimisation	Only fields needed to bill and serve; optional fields off by default; national ID encrypted at field level

4.1 Encryption and keys

- TLS 1.2+ everywhere (HSTS); internal service traffic encrypted.
- Encryption at rest for databases, object storage and backups using KMS keys; **per-cell keys**, and per-tenant keys for silo cells.
- Field-level encryption for national ID and similar identifiers (envelope encryption; keys in KMS); blind index for lookup where needed.
- Secrets in a secrets manager, rotated; no secrets in repos or logs; short-lived credentials for CI and humans.

// 5. Payment and money security

- **Funds flow to the tenant's own Paybill/Till**; the platform does not hold customer funds in the baseline design. Confirm with Safaricom and counsel, and revisit before offering any aggregation or wallet feature, which could bring payment-service licensing questions.
- Callback endpoints use unguessable paths, source allow-listing, payload schema validation, and **verification against the provider's transaction status** before large or unusual postings.
- Daraja credentials and shortcodes per tenant in the secrets manager; rotation runbook.
- Idempotency by unique constraint; replay-safe; every payment linked to a journal and audit event.
- Daily reconciliation against provider statements; variance alerts; suspense account with ageing and owner.
- Cash and cheque payments require cashier sessions with end-of-day reconciliation and supervisor close-out.
- No card data is stored. If card payments are added, use a PCI-compliant hosted flow so the platform stays out of PCI scope.

// 6. Application and infrastructure security

Area	Standard
Secure SDLC	Threat model per major feature; security acceptance criteria in specs; SAST/dependency scanning in CI; secret scanning; mandatory review for sensitive paths
Web	CSP, CSRF protection, output encoding, strict file upload checks, rate limiting, bot protection on public forms
Tenancy	RLS policy-coverage CI test; cross-tenant integration tests per module; FORCE RLS; no BYPASSRLS roles in app
Network	Private subnets for app/data; no public DB; security groups least privilege; admin access through SSM/VPN with MFA
Hardening	Minimal base images, non-root containers, read-only filesystems, patch cadence (critical 72 h, high 14 days)
Testing	External penetration test before pilot and annually; bug bounty/disclosure policy later; tabletop incident exercises
Mobile	Encrypted local DB (SQLCipher), certificate pinning for API, root/jailbreak signals, no PII in screenshots/logs

6.1 Incident response

1. **Detect:** alerts from audit verifier, WAF, anomaly rules, customer reports.
2. **Triage:** incident commander assigned; severity set (S1 = data exposure or money integrity).
3. **Contain:** revoke sessions/keys, isolate cell or tenant, block IPs, disable integration.
4. **Eradicate and recover:** patch, rotate secrets, restore from PITR if needed, replay payments from inbox.
5. **Notify:** affected tenants immediately; regulatory and data-subject notices coordinated with the controller.
6. **Learn:** blameless review within 5 working days; actions tracked to completion.

6.2 Compliance backlog and company readiness

Item	Owner	When
Register the company, obtain tax PIN, open business bank account	Founders	Before signing any contract
Register with ODPC as applicable; appoint a data protection lead	Founders + counsel	Before processing real customer data
Data processing agreement + partner agreement templates	Counsel	Before pilot
Policies: security, access control, incident response, backup, retention	Tech lead	Before pilot
Penetration test and remediation	Security vendor	Before production go-live
Insurance (professional indemnity / cyber) quotation	Founders	Before scale-out